

PRD-03: 用户角色与权限体系

版本: 1.0

日期: 2025-12

状态: 已实施

1. 概述

1.1 文档目的

本文档定义 Blaze Robotics Academy 平台的用户角色、权限体系和认证授权机制，确保系统安全性和用户体验。

1.2 设计原则

- 最小权限原则**：用户只能访问其角色所需的功能和数据
- 数据隔离**：不同角色的数据访问范围明确隔离
- 可扩展性**：支持未来新增角色和权限
- 安全性**：多层安全防护，防止未授权访问

2. 用户角色定义

2.1 角色列表

角色	标识	描述	主要用途
访客	guest	未登录用户	浏览公开内容
用户	user	注册学生/家长	浏览课程、报名、查看个人资料
教练	coach	课程讲师	查看分配的课程、管理课程日历

管理员	admin	系统管理员	管理所有功能和数据
-----	-------	-------	-----------

2.2 角色详细说明

2.2.1 访客 (Guest)

- 权限范围：
 - ☒ 浏览公开网站
 - ☒ 查看课程目录
 - ☒ 查看课程详情
 - ☒ 查看学习路径
 - ☒ 查看团队介绍
 - ☒ 使用 AI 客服
 - ☒ 报名课程
 - ☒ 查看个人资料
 - ☒ 访问管理功能

2.2.2 用户 (User)

- 权限范围：
 - ☒ 访客的所有权限
 - ☒ 报名课程
 - ☒ 管理购物车
 - ☒ 加入等待列表
 - ☒ 查看个人资料
 - ☒ 查看报名记录
 - ☒ 管理支付方式
 - ☒ 查看学习进度
 - ☒ 访问管理功能
 - ☒ 访问教练功能

2.2.3 教练 (Coach)

- 权限范围：
 - ☒ 用户的所有权限 (可选)
 - ☒ 查看分配的课程
 - ☒ 查看课程详情 (只读)
 - ☒ 查看课程日历

-  导出课程 (iCalendar)
-  查看课程统计
-  编辑课程信息
-  管理用户
-  管理其他教练的课程

2.2.4 管理员 (Admin)

- 权限范围：
 -  所有角色的权限
 -  管理用户
 -  管理课程
 -  管理报名
 -  管理团队
 -  管理 Franchise
 -  查看数据统计
 -  系统配置

3. 权限矩阵

3.1 功能权限矩阵

功能模块	访客	用户	教练	管理员
公开网站				
浏览首页				
浏览课程目录				
查看课程详情				
查看学习路径				
使用 AI 客服				
用户功能				

注册/登录	✓	✓	✓	✓
报名课程	✗	✓	✓	✓
管理购物车	✗	✓	✓	✓
查看个人资料	✗	✓	✓	✓
管理支付方式	✗	✓	✓	✓
教练功能				
查看分配的课程	✗	✗	✓	✓
导出课程日历	✗	✗	✓	✓
查看课程统计	✗	✗	✓	✓
管理员功能				
用户管理	✗	✗	✗	✓
课程管理	✗	✗	✗	✓
报名管理	✗	✗	✗	✓
团队管理	✗	✗	✗	✓
Franchise 管理	✗	✗	✗	✓
数据统计	✗	✗	✗	✓

3.2 数据访问权限矩阵

数据类型	访客	用户	教练	管理员
公开数据				
课程信息（已发布）	✓	✓	✓	✓

学习路径	✓	✓	✓	✓
团队信息	✓	✓	✓	✓
个人数据				
自己的资料	✗	✓	✓	✓
自己的报名	✗	✓	✓	✓
自己的支付方式	✗	✓	✓	✓
教练数据				
分配的课程	✗	✗	✓	✓
课程学生列表	✗	✗	✓	✓
管理数据				
所有用户	✗	✗	✗	✓
所有课程	✗	✗	✗	✓
所有报名	✗	✗	✗	✓
系统配置	✗	✗	✗	✓

4. 认证机制

4.1 认证方式

4.1.1 邮箱/密码认证

- 注册流程：
 1. 用户填写邮箱、密码、姓名
 2. 系统创建用户账户（状态：未验证）

3. 发送验证邮件
4. 用户点击邮件链接验证邮箱
5. 账户状态更新为已验证

- **登录流程：**

1. 用户输入邮箱和密码
2. 系统验证凭据
3. 创建 Session (JWT)
4. 返回用户信息和角色

4.1.2 Google OAuth 认证

- **登录流程：**

1. 用户点击 "Sign in with Google"
2. 跳转到 Google 授权页面
3. 用户授权后，Google 返回用户信息
4. 系统检查用户是否存在：
 - 存在：更新信息，创建 Session
 - 不存在：创建新用户，创建 Session
5. 返回用户信息和角色

4.1.3 密码重置

- **流程：**

1. 用户点击 "Forgot Password"
2. 输入邮箱地址
3. 系统发送重置链接（带令牌）
4. 用户点击链接，设置新密码
5. 令牌验证后更新密码

4.2 Session 管理

- **技术：** NextAuth.js JWT Session
 - **存储：** JWT Token（客户端）
 - **过期时间：** 30 天（可配置）
 - **刷新机制：** 自动刷新（NextAuth.js 处理）
-

5. 授权机制

5.1 路由保护

5.1.1 公开路由

- `/` : 首页
- `/course-catalog` : 课程目录
- `/course-catalog/[slug]` : 课程详情
- `/learning-paths` : 学习路径
- `/locations/[code]` : Franchise 页面
- `/login` : 登录页
- `/register` : 注册页

5.1.2 用户路由（需要登录）

- `/profile` : 个人资料
- `/enrollments/cart` : 购物车
- `/enrollments/waitlist` : 等待列表
- `/enrollments/success` : 支付成功
- `/enrollments/cancel` : 支付取消

5.1.3 教练路由（需要 coach 或 admin 角色）

- `/coach` : 教练仪表盘
- `/coach/classes` : 我的课程
- `/coach/classes/[id]` : 课程详情
- `/coach/schedule` : 课程表

5.1.4 管理员路由（需要 admin 角色）

- `/admin` : 管理员仪表盘
- `/admin/users` : 用户管理
- `/admin/courses` : 课程管理
- `/admin/enrollments` : 报名管理
- `/admin/teams` : 团队管理
- `/admin/franchises` : Franchise 管理
- `/admin/instances` : 实例管理

- `/admin/categories` : 分类管理
- `/admin/series` : 系列管理
- `/admin/subcategories` : 子类管理
- `/admin/assignments` : 分配管理
- `/admin/locations` : 地点管理
- `/admin/learning-paths` : 学习路径管理

5.2 API 保护

5.2.1 公开 API

- `GET /api/courses` : 获取课程列表
- `GET /api/courses/[id]` : 获取课程详情
- `GET /api/public/franchises` : 获取 Franchise 列表
- `GET /api/learning-paths` : 获取学习路径列表

5.2.2 用户 API (需要登录)

- `GET /api/user/profile` : 获取个人资料
- `POST /api/user/profile` : 更新个人资料
- `GET /api/user/enrollments` : 获取报名记录
- `POST /api/enrollments/cart` : 加入购物车
- `GET /api/enrollments/cart` : 获取购物车
- `GET /api/user/payment-methods` : 获取支付方式
- `POST /api/user/payment-methods` : 添加支付方式

5.2.3 教练 API (需要 coach 或 admin 角色)

- `GET /api/coach/instances` : 获取分配的课程
- `GET /api/coach/instances/[id]` : 获取课程详情
- `GET /api/coach/instances/[id]/export` : 导出课程
- `GET /api/coach/stats` : 获取统计信息

5.2.4 管理员 API (需要 admin 角色)

- `GET /api/admin/users` : 获取用户列表
- `POST /api/admin/users` : 创建用户
- `PATCH /api/admin/users/[id]` : 更新用户
- `DELETE /api/admin/users/[id]` : 删除用户

- `GET /api/admin/courses` : 获取课程列表
- `POST /api/admin/courses` : 创建课程
- `PATCH /api/admin/courses/[id]` : 更新课程
- `DELETE /api/admin/courses/[id]` : 删除课程
- 其他管理 API...

5.3 数据访问控制

5.3.1 Row Level Security (RLS)

- 技术: Supabase RLS 策略
- 原则: 用户只能访问自己的数据
- 实现:
 - 用户表: 只能查看和更新自己的记录
 - 报名表: 只能查看自己的报名记录
 - 支付方式: 只能查看自己的支付方式

5.3.2 应用层权限检查

- **API 路由**: 检查 Session 和角色
 - **数据查询**: 基于用户 ID 和角色过滤
 - **操作验证**: 验证数据所有权
-

6. 用户生命周期

6.1 用户注册流程

访客 → 填写注册信息 → 创建账户（未验证） → 发送验证邮件 →
用户点击验证链接 → 账户验证成功 → 可以登录

6.2 用户登录流程

访客 → 输入凭据 → 验证成功 → 创建 Session → 跳转到目标页面

6.3 角色分配流程

6.3.1 默认角色

- 新注册用户默认角色：`user`

6.3.2 角色升级

- 升级为教练：
 - 管理员在用户管理界面设置
 - 或通过数据库直接更新 `users.role = 'coach'`
 - 需要关联 `course_instance_coaches` 表
- 升级为管理员：
 - 只能由现有管理员设置
 - 或通过数据库直接更新 `users.role = 'admin'`

6.4 用户删除流程

管理员删除用户 → 检查关联数据 →
删除关联数据（CASCADE） → 删除用户记录

关联数据删除规则：

- `course_enrollments`：CASCADE 删除
- `teams`：CASCADE 删除（如果用户是教练）
- `course_instance_coaches`：CASCADE 删除

7. 安全措施

7.1 密码安全

- 加密算法：`bcryptjs`（10 rounds）
- 密码要求：
 - 最小长度：8 字符（建议）
 - 建议包含：大小写字母、数字、特殊字符
- 密码重置：
 - 令牌过期时间：1 小时

- 单次使用令牌
- 令牌验证后立即失效

7.2 邮箱验证

- 验证令牌：随机生成（32 字节）
- 过期时间：24 小时
- 单次使用：验证后立即失效
- 重发机制：支持重新发送验证邮件

7.3 Session 安全

- JWT 签名：使用 `AUTH_SECRET`
- HTTPS 传输：生产环境强制 HTTPS
- Token 过期：30 天自动过期
- 刷新机制：自动刷新（NextAuth.js）

7.4 API 安全

- 认证检查：所有受保护 API 验证 Session
 - 角色验证：检查用户角色
 - 数据所有权：验证数据属于当前用户
 - 输入验证：验证和清理所有输入
 - SQL 注入防护：使用参数化查询
-

8. 特殊场景处理

8.1 多角色用户

- 场景：用户可能同时是 `user` 和 `coach`
- 处理：系统支持用户拥有多个角色（通过 `role` 字段）
- 当前实现：单一角色（`user`、`coach` 或 `admin`）
- 未来扩展：支持角色数组（`roles: string[]`）

8.2 教练课程访问

- 规则：教练只能查看分配给自己的课程
- 实现：通过 `course_instance_coaches` 表关联
- 查询：过滤 `coach_id = current_user.id`

8.3 管理员权限

- 规则：管理员拥有所有权限
- 实现：API 检查 `role === 'admin'` 时跳过权限检查
- 数据访问：使用 `supabaseAdmin`（服务角色）绕过 RLS

9. 权限配置

9.1 数据库配置

```
-- 用户角色约束
ALTER TABLE users
  ADD CONSTRAINT users_role_check
  CHECK (role IN ('user', 'admin', 'coach'));
```

9.2 应用配置

```
// src/auth.ts
export const authConfig = {
  // 角色定义
  roles: ['user', 'coach', 'admin'],

  // 路由保护
  protectedRoutes: {
    user: ['/profile', '/enrollments/*'],
    coach: ['/coach/*'],
    admin: ['/admin/*'],
  },
}
```

10. 测试场景

10.1 认证测试

- ☒ 用户注册
- ☒ 邮箱验证
- ☒ 登录（邮箱/密码）
- ☒ 登录（Google OAuth）
- ☒ 密码重置
- ☒ Session 过期处理

10.2 授权测试

- ☒ 访客访问公开页面
- ☒ 访客无法访问受保护页面
- ☒ 用户访问用户功能
- ☒ 用户无法访问管理功能
- ☒ 教练访问教练功能
- ☒ 教练无法访问其他教练的课程
- ☒ 管理员访问所有功能

10.3 数据访问测试

- ☒ 用户只能查看自己的数据
 - ☒ 教练只能查看分配的课程
 - ☒ 管理员可以查看所有数据
 - ☒ RLS 策略正确执行
-

11. 未来扩展

11.1 多角色支持

- 支持用户拥有多个角色
- 角色权限叠加
- 角色优先级管理

11.2 细粒度权限

- 基于资源的权限控制
- 自定义权限组
- 权限继承机制

11.3 审计日志

- 记录所有权限操作
 - 登录日志
 - 权限变更历史
-

12. 附录

12.1 相关文档

- `ADMIN_SETUP.md` : 管理员设置指南
- `COACH_PORTAL_DESIGN.md` : 教练门户设计
- `AUTH_SETUP.md` : 认证设置指南

12.2 技术参考

- [NextAuth.js 文档](#)
- [Supabase RLS 文档](#)